

ETSI EN 304 624

**Essential cybersecurity requirements for Public Key
Infrastructure and digital certificate issuance software**

Deep Dive Session

Presented by Sammy HADDAD

[Directory Listing /CYBER/EUSR/Open](#)



Agenda





Deep Dive Session Agenda

- General Introduction of the session
- CRA Context reminder
- ETSI STAN4CR2 project
- PKI vertical standard (ETSI EN 304 624) overview
- Q&A Session

CRA Context



Regulation (EU) 2024/2847 - Cyber Resilience Act (CRA)



CRA is a European regulation that sets security requirements for digital products seeking to enter the European market

- Aims to **address increasing threats** faced by hardware and software products
- Defines **mandatory requirements** for manufacturers and developers **throughout product lifecycle**
 - Risk-based approach
 - Identifies important products (Annex III)...
 - ... and their associated security requirements (Annex I)

CRA Annex I - Requirements



ANNEX I

ESSENTIAL CYBERSECURITY REQUIREMENTS

Part I Cybersecurity requirements relating to the properties of products with digital elements

- (1) Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.
- (2) On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:
 - (a) be made available on the market without known exploitable vulnerabilities;
 - (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state;
 - (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;
 - (d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;
 - (e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;
 - (f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;
 - (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);
 - (h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;
 - (i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;
 - (j) be designed, developed and produced to limit attack surfaces, including external interfaces;
 - (k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;
 - (l) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;
 - (m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

Part II Vulnerability handling requirements

Manufacturers of products with digital elements shall:

- (1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;

- 2 parts
 - 14 **Cybersecurity** requirements
 - 8 **Vulnerability handling** requirements
- High level Cybersecurity requirements
 - *No known vulnerability, Secure update, Access control, Data and attack surface minimization ...*

ETSI STAN4CR2 project



STAN4CR2 Project Overview



- Objective
 - **Answer CRA Standardisation Request**
 - To strengthen cybersecurity for hardware and software products across the EU.
 - To Advance harmonized European standards for cybersecurity.
- Activities:
 - **Development of CRA Standardisation Request deliverables**
 - **Dissemination**
 - Introduction of Rapporteurs in relevant working groups (CEN, CENELEC, ETSI)
 - Coordination across diverse cybersecurity topics
 - Foster collaboration with stakeholders to ensure alignment and adoption
 - Fundings from the European Commission and support from ENISA
 - Vertical Standards

STAN4CR2 Project Vertical standards



ANNEX III

IMPORTANT PRODUCTS WITH DIGITAL ELEMENTS

Class I

1. Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers
2. Standalone and embedded browsers
3. Password managers
4. Software that searches for, removes, or quarantines malicious software
5. Products with digital elements with the function of virtual private network (VPN)
6. Network management systems
7. Security information and event management (SIEM) systems
8. Boot managers
9. Public key infrastructure and digital certificate issuance software
10. Physical and virtual network interfaces
11. Operating systems
12. Routers, modems intended for the connection to the internet, and switches
13. Microprocessors with security-related functionalities
14. Microcontrollers with security-related functionalities
15. Application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities
16. Smart home general purpose virtual assistants
17. Smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems
18. Internet connected toys covered by Directive 2009/48/EC of the European Parliament and of the Council (1) that have social interactive features (e.g. speaking or filming) or that have location tracking features
19. Personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/745 or (EU) No 2017/746 do not apply, or personal wearable products that are intended for the use by and for children

Class II

1. Hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments
2. Firewalls, intrusion detection and prevention systems
3. Tamper-resistant microprocessors
4. Tamper-resistant microcontrollers

- Standards for 16 Class I important products (out of 19)
 - As defined in CRA Annex III
 - Identity management, browsers, Password managers, VPN, Network management systems, Boot managers, Public key infrastructure, etc.
- Defined for presumption of conformity to CRA requirements
 - i. e. conformity to the standard ensures conformity to the CRA
- Follow the risk-based approach required by the CRA by all following the same structure (presented in more details later)
 - Core
 - Scope / security problem definition, Cybersecurity Requirements, Assessment requirements
 - Annexes
 - Conformity rationales and risk analysis

ETSI EN 304 624 overview - PKI vertical



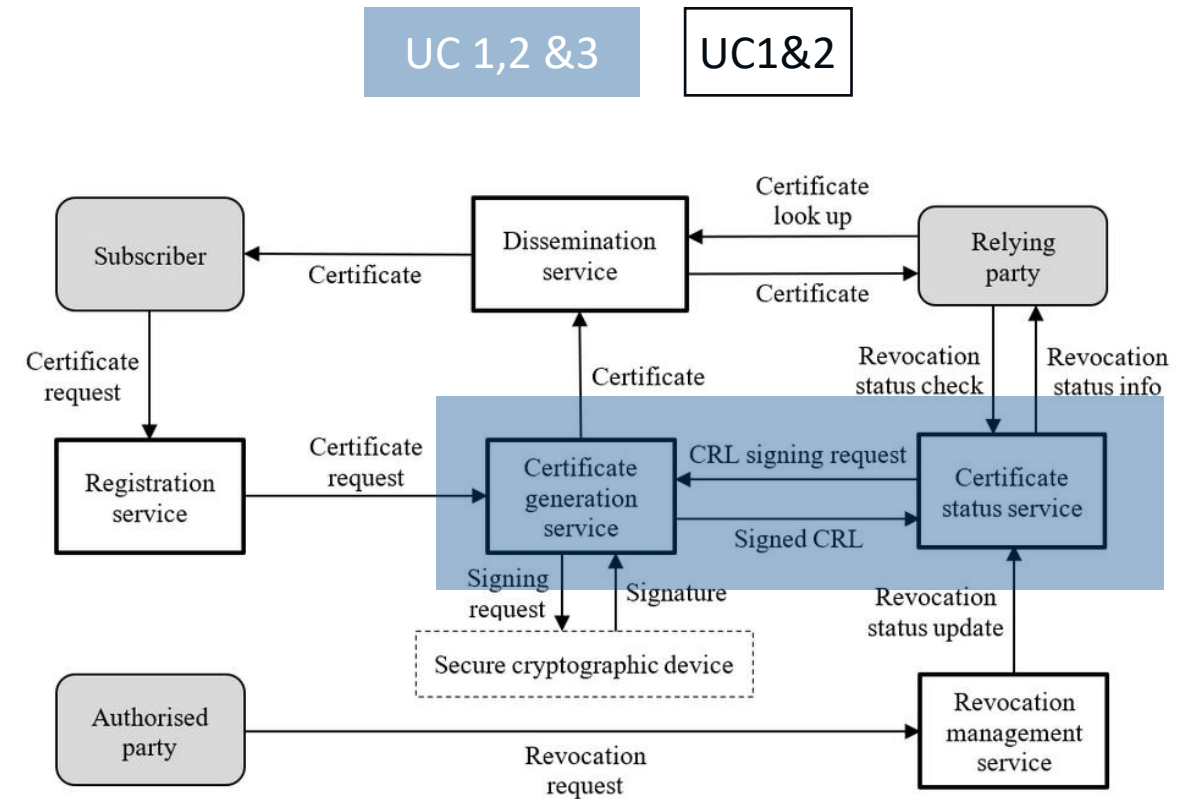
ETSI EN 304 624 – Detailed structure



- Scope
 - CRA context
- Definitions and terms
- PKI software contexts
 - Intended purpose of use
 - Main functionalities
 - Architecture
 - Operational environment
 - Users
 - Uses cases
 - Defined by functionalities, assets and threats
- Cybersecurity Requirements
- Conformity Assessment Requirements
- Annex A – *Mapping with essential CRA requirements*
- Annex B – *Mapping of Threats to security requirements*
- Annex C – *Risk evaluation*
- Annex D – *Cryptography*

4 (+1) Use Cases

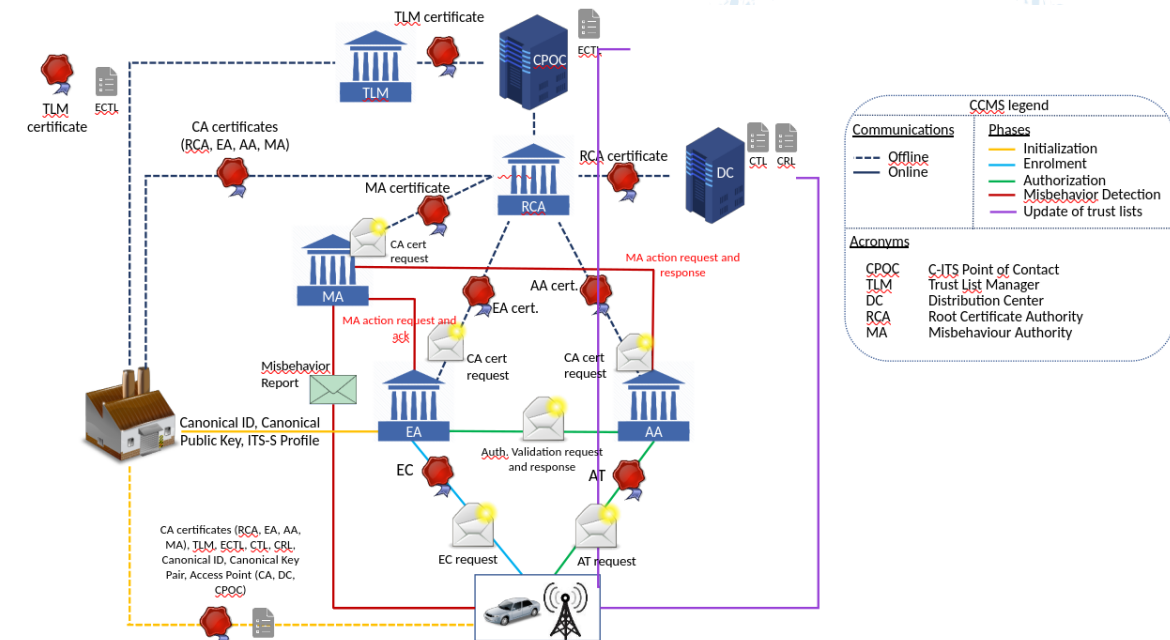
- *UC1* - Private PKI for non-critical infrastructure
 - PKIs providing the widest scope of functionalities
 - Registration, Certificate generation, Dissemination, Revocation management, Certificate status, Logging of security events, User accounts management
- *UC2* - Private PKI for critical infrastructure
 - Same as before but with higher environmental constraints and higher risks
- *UC3* - Public PKI / CA certificate generation PKI
 - Smaller functional scope
 - No request management, no certificate distribution, etc.
 - Only certificate creation and status management



4 (+1) Use Cases

- **UC4 - C-ITS PKI**
 - Different architecture
 - Two types of certificates instead of one
 - Long-term and short-term
 - Not ITU-T X.509 -> ETSI TS 103 097
 - Different authorities types and roles
- **UC5 - Machine to machine (TBD)**
 - No secure module / HSM
 - The software generates the key pairs

C-ITS PKI Architecture



Cybersecurity requirements



About 30 cybersecurity requirements (clause 5) and their associated assessment requirements (clause 6) , categorized as follow :

- Audit
- Secret management
- Certificate issuance
- Certificate status
- Certificate renewal
- Certificate re-key
- Certificate modification
- Certificate suspension and revocation
- Certificate status services
- Access control
- Secure communications with external entities

Cybersecurity requirements – Examples (I)



Secret Management

- REFERENCE: REQ-5.2-01
 - **REQUIREMENT:** The PKI shall only create key pairs keys by means of a secure cryptographic device appropriate for this use.
 - **RATIONALE:** To ensure trust the PKI software should rely on secure and valid key creation and management systems accessible only to authorised users provided by hardware security devices. It covers key tampering and disclosure threats: T_GEN01 to T_GEN08, T.Stored_Certificates_Tampering.
 - **APPLICABILITY:** All use cases
- REFERENCE: REQ-5.2-03
 - **REQUIREMENT:** Public keys stored within the PKI, but not within a secure cryptographic device, shall be protected against undetected modification. If verification fails, the PKI shall not:
 - a) release the accessed public key to the caller; or
 - b) use the accessed public key.
 - **RATIONALE:** Unauthorized modifications of public keys stored by the PKI should not go undetected. Public keys modified without authorization should not be considered safe for use and not be disseminated throughout or outside the PKI. This requirement covers key tampering and disclosure threats: T_GEN01 to T_GEN08, T.Stored_Certificates_Tampering.
 - **APPLICABILITY:** All use cases

Cybersecurity requirements – Examples (II)



Certificate issuance

- REFERENCE: REQ-5.3-02
 - **REQUIREMENT:** The certificates issued by the certificate generation service shall be public-key certificates or attribute certificates whose format complies with the X.509 standard ITU-T X.509 [1].
 - **RATIONALE:** Public-key certificates shall use version 3 certificates since this standard requires the use of certificates extensions.
 - **NOTE:** At a minimum, the PKI should ensure that:
 - a) the version field should contain the integer 2 or 3;
 - b) the serialNumber should be unique with respect to the issuing Certification Authority;
 - c) the validity field shall specify a notBefore value that does not precede the current time and a notAfter value that does not precede the value specified in notBefore;
 - d) if the issuer field contains a null Name (e.g. a sequence of zero relative distinguished names), then the certificate should contain a critical issuerAltName extension;
 - e) if the subject field contains a null Name (e.g. a sequence of zero relative distinguished names), then the certificate should contain a critical subjectAltName extension;
 - f) the signature field and the algorithm in the subjectPublicKeyInfo field shall designate a recommended agreed signature algorithm [ETSI TS 119 312].
 - **APPLICABILITY:** All use cases where the PKI has a certificate generation service, issuing public-key certificates.

Assessment requirements – Examples (I)



Auditing

- **REFERENCE:** ASS-REQ-6.2-01
 - **OBJECTIVE:** Verify that the PKI records within each audit record the required information, and that these records do not include any secret key or other secret parameter in plaintext form.
 - **PREPARATION:** Ability to trigger auditable events, and ability to audit events.
 - **ACTIVITIES:** Trigger an auditable event. Access the corresponding audit record.
 - Verify the audit record contains at least:
 - a) the date and time of the event;
 - b) the type of the event;
 - c) the subject identity (if applicable);
 - d) the outcome of the event.
 - Perform the above for each audit event type, and verify that the audit record additionally contains the additional information specified by the developer.
 - For each information verified to be present, verify it matches the expected value given when and how the event was triggered.
 - For each of the generated audit record, verify that no private or symmetric key, as well as no other secret parameter is present in plaintext form.
 - **VERDICT:** SUCCESS if all the verifications pass; else FAIL.
 - **EVIDENCE:** The way the events were triggered and at what time, and the corresponding audit records.

Annex A - Mapping with CRA essential req.

No	Description	Clause(s) of the present document
(1)	Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.	Annex C
(2)(a)	Be made available on the market without known exploitable vulnerabilities.	6.1
(2)(b)	Be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state.	5
(2)(c)	Ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them.	6.1
(2)(d)	Ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access.	5.1, 5.3, 6.2 & 6.4
(2)(e)	Protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means.	5.1 5.2, 6.2 & 6.3
(2)(f)	Protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions.	5.1, 5.2, 5.3, 5.4, 5.7, 5.9
(2)(g)	Process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation).	5
(2)(h)	Protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks.	5.1 5.2, 6.2 & 6.3
...	...	...

Annex B – Mapping of threats to requirements

Threat		Associated requirement	
ID	Description	Requirements	Assessment
T_SYS01	Exploiting insecure settings in default system configuration data	REQ-5.10-[01-02]	Clause 6.6
T_SYS02	Modifying settings in unprotected system configuration data	REQ-5.1-[01-08], REQ-5.5-01, REQ-5.6-01, REQ-5.7-01, REQ-5.10-[01-02]	Clause 6.2, 6.3, 6.6, Clause 6.7, Clause 6.3, Clause 6.3, Clause 6.6
T_SYS03	Disclosing sensitive parameters in unprotected system configuration data	REQ-5.10-[01-02]	Clause 6.6
T_SYS04	Exploiting insecure user authentication credentials or access rights in default user account data	REQ-5.1-[01-08], REQ-5.5-01, REQ-5.6-01, REQ-5.7-01, REQ-5.10-[01-02]	Clause 6.2, 6.3, 6.6, Clause 6.7, Clause 6.3, Clause 6.3, Clause 6.6
T_SYS05	Modifying user authentication credentials or access rights in unprotected user account data	REQ-5.1-[01-08], REQ-5.5-01, REQ-5.6-01, REQ-5.7-01, REQ-5.10-[01-02]	Clause 6.2, 6.3, 6.6, Clause 6.7, Clause 6.3, Clause 6.3, Clause 6.6
T_SYS06	Disclosing user authentication credentials in unprotected user account data	REQ-5.10-[01-02]	Clause 6.6
T_SYS07	Modifying or deleting events in unprotected event log data	REQ-5.1-[01-08], REQ-5.5-01, REQ-5.6-01, REQ-5.7-01, REQ-5.10-[01-02]	Clause 6.2, 6.3, 6.6, Clause 6.7, Clause 6.3, Clause 6.3, Clause 6.6
T_SYS08	Accessing settings or sensitive parameters via an unprotected system configuration management function	REQ-5.10-[01-02]	Clause 6.6
T_SYS09	Accessing user authentication credentials or access rights via an unprotected user account management function	REQ-5.10-[01-02]	Clause 6.6
T_SYS10	Accessing event logs via an unprotected event log management function	REQ-5.1-[01-08], REQ-5.5-01, REQ-5.6-01, REQ-5.7-01, REQ-5.10-[01-02]	Clause 6.2, 6.3, 6.6, Clause 6.7, Clause 6.3, Clause 6.3, Clause 6.6
T_SYS11	Disabling or rolling back software updates via an unprotected software update function	REQ-5.10-[01-02]	Clause 6.6
T_REG01	Modifying information in unprotected subscriber data	REQ-5.1-[01-08], REQ-5.5-01, REQ-5.6-01, REQ-5.7-01, REQ-5.3-[01-07]	Clause 6.2, 6.3, 6.6, Clause 6.7, Clause 6.3, Clause 6.3, Clause 6.4

- ## Information security, interface exposure

Information security, interface exposure

Annex D - Cryptography

Common to all/most standards

- D.1 State of the art requirement
 - *“The product shall, by default, use State-of-the-Art cryptography algorithms listed in (CRY-SOTA), to be used for the supported security mechanism of the product where applicable”*
 - ENISA Report 1747792503 (04-2025): "European Cybersecurity Certification Group Sub-group on Cryptography Agreed Cryptographic Mechanisms - version 2".
- D.2 Crypto agility
 - *“Where applicable the product shall by default be prepared to update cryptographic algorithm used for the supported security mechanism of the product to maintain when there are indications that the used cryptographic algorithm will not stay SOTA anymore within the intended lifetime of the product”*

Q&A





Thank you for your attention



Co-funded by
the European Union

Follow us on:   